

Anonymity-Preserving, Decoupled Distributed Authentication for Multihop IoT Networks

M.Tech. Project (MTP) Defence

Anup Kulkarni

Guide: Prof. Manas Khatua

Department of Computer Science and Engineering
Indian Institute of Technology Guwahati



June 2026

Outline of Presentation

- 1 Introduction
- 2 Background & Literature Survey
- 3 Motivation & Contributions
- 4 Proposed Scheme
- 5 Security & Performance Evaluation
- 6 Conclusion

Outline

- 1 Introduction
- 2 Background & Literature Survey
- 3 Motivation & Contributions
- 4 Proposed Scheme
- 5 Security & Performance Evaluation
- 6 Conclusion

The Internet of Things (IoT)

What is IoT?

- A network of everyday physical objects – sensors, actuators, smart devices – embedded with computing and connectivity.
- They **sense, exchange, and act** on data with little human intervention, reporting to gateways/cloud over an **open wireless channel** (often via multihop relays).

Why is authentication needed?

- Authentication ensures that **only legitimate devices** participate in the network – preventing **impersonation**, **unauthorized access**, and **replay attacks**, and enabling **secure session-key establishment**.

Core tension

Strong security

vs.

Low energy / CPU cost

on devices that cannot afford heavy cryptography.

Centralized vs. Distributed Authentication

Centralized schemes

All authentication traffic is routed through a single gateway $\Rightarrow$ **excessive relay load** on intermediate nodes in a multihop topology.

Plain (parent-centric) distributed schemes

Each parent authenticates its own children $\Rightarrow$ whichever node a burst of new devices joins under is **overloaded**, while other capable nodes stay **idle**. This is the **skewed-load** problem.

DAuth (base scheme, Das & Khatua, COMSNETS 2026)

A **decoupled** distributed scheme: the gateway pre-assigns *any* capable node (parent or non-parent) as the Authentication Server (AS), spreading the load evenly. Uses **PUF**-based secrets, a **hash-based accumulator**, and **XOR**-masked messages.

Outline

- 1 Introduction
- 2 Background & Literature Survey**
- 3 Motivation & Contributions
- 4 Proposed Scheme
- 5 Security & Performance Evaluation
- 6 Conclusion

IoT Authentication Architectures

Authentication in IoT typically involves three entities:

- User / device U_i
- Sensor / peer node S_j
- Gateway node (GWN)

Four prevalent communication architectures (a)–(d) differ in how the gateway mediates the exchange. Our work targets the **multihop** device–gateway path with a **distributed** authenticator.

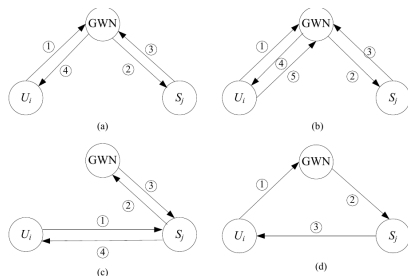


Figure 3. Four basic system architectures for authentication in IoT environments.

Source: Zhong *et al.*, “Lightweight Anonymous Authentication for IoT,” *Sensors* 2025.

- **Centralized** schemes (Sheik'23, He'23, Roy'25): high computation/communication overhead in multihop networks.
- **Distributed** schemes (RAAF-MEC'25): skewed load on particular fog/edge servers; ignore multihop IoT.
- **LightSAE'23**: parents authenticate children $\Rightarrow$ skewed overhead.
- **PUF-based P2P** (Li'20, Zheng'22): avoid long-term key storage, but still skewed; ECC operations make them heavy.
- **LAACA'24, Zhou et al.'24**: provide anonymity, but rely on **computationally intensive** operations $\Rightarrow$ far higher overhead than DAuth.
- **DAuth'26 (base scheme, Das & Khatua)**: **decoupled** distributed PUF-based scheme with a hash accumulator $\Rightarrow$ lightweight, but **no anonymity** and **no desync recovery**.

Feature Comparison of Authentication Schemes

Scheme	Dec.	PUF	Acc.	Anon.	Desync	C.OH	M.OH
RAAF-MEC '25	×	✓	×	×	×	H	L
SAKMS '24	✓	×	×	×	×	H	L
Li et al. '20	✓	✓	×	×	×	H	L
Zheng et al. '22	✓	✓	×	×	×	M	L
LAACA '24	×	×	×	✓	×	L	L
Zhou et al. '24	×	✓	×	✓	×	M	M
DAuth '26 (base)	✓	✓	✓	×	×	L	L
Proposed	✓	✓	✓	✓	✓	L	L

Dec.: Decoupled **Acc.:** Hash accumulator **Anon.:** Anonymity **Desync:** Recovery
C.OH: Computation (L=Hash/XOR/ ≤ 2 AES, M= > 2 AES, H=ECC/Pairings) **M.OH:**
Messages (L=1–3, M=4–5, H= > 5)

Only the proposed scheme satisfies every criterion at the lowest overhead.

Outline

- 1 Introduction
- 2 Background & Literature Survey
- 3 Motivation & Contributions**
- 4 Proposed Scheme
- 5 Security & Performance Evaluation
- 6 Conclusion

Motivation: Two Gaps in DAuth

DAuth is the closest match in the comparison, yet it leaves **two critical security gaps** unaddressed:

- ❶ **No anonymity.** The real device identity ID_D is sent in **plaintext on the open channel in every session**.
 - An adversary with radio access can **track a device across sessions**.
 - Direct violation of modern privacy requirements.
- ❷ **No desynchronisation recovery.** AS and device keep only a **single session state**.
 - A single lost packet during key delivery **desynchronises** their states.
 - All future authentications fail until **full re-enrolment** – an energy-costly operation for a battery-powered node.

Our Contributions

We extend DAuth with **two lightweight mechanisms** that close both gaps:

1. Per-session Pseudonym Rotation (Anonymity)

Real identity ID_D never leaves the secure enrolment channel. Open-channel messages carry a rotating pseudonym $PID = H(ID_D \parallel m_{\text{curr}})$, refreshed after every key exchange $\Rightarrow$ successive sessions are **unlinkable**.

2. Dual-State Synchronisation (Desync Recovery)

AS and gateway store *both* $(m_{\text{curr}}, PID_{\text{curr}})$ and $(m_{\text{old}}, PID_{\text{old}})$ $\Rightarrow$ recover from a single packet loss **without re-enrolment**.

- Formally verified in **ProVerif** (Dolev–Yao model).
- Evaluated via **theoretical**, **COOJA/Contiki-NG simulation**, and **hardware (RPI 4B)** analysis.

Outline

- 1 Introduction
- 2 Background & Literature Survey
- 3 Motivation & Contributions
- 4 Proposed Scheme**
- 5 Security & Performance Evaluation
- 6 Conclusion

System Model & Assumptions

Entities

- D – newly joined device (has a PUF, identity ID_D).
- AS – authentication server: *any* capable node pre-selected by the gateway (parent or non-parent).
- GW – gateway / root node.

Assumptions

- GW shares a long-term key K_{GW-AS} with each AS .
- D knows the address and identity ID_{AS} of its AS .
- Nodes can do hash, AES, XOR, AND, concat, and PUF eval.

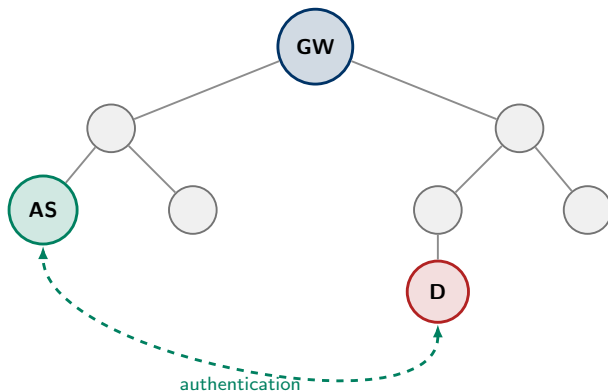
Three protocol phases

- 1 **Enrolment**
(once, secure channel)
- 2 **Authentication**
(open channel)
- 3 **Key Exchange**
(open channel)

Decoupling

Authentication is *decoupled* from network joining – no parent is overwhelmed by its children.

Network Topology – Decoupled Authentication



D new device | **AS** gateway-selected authenticator | **GW** gateway / root

Decoupling: D's authenticator (AS) may or may not be its RPL parent – GW may pick any capable node, so no single parent is overloaded.

Key Idea 1 – Per-Session Pseudonym Rotation

- Real ID_D is sent **only once**, over the secure enrolment channel.
- Every open-channel message uses a pseudonym:

$$PID = H(ID_D \parallel m_{\text{curr}})$$

- After each key exchange, $m_{\text{curr}} \rightarrow m_{\text{new}}$, so PID rotates.
- H is one-way and m_{curr} is private $\Rightarrow$ consecutive pseudonyms are **computationally unlinkable**.

Effect

Session 1: $PID_1 = H(ID_D \parallel m_1)$

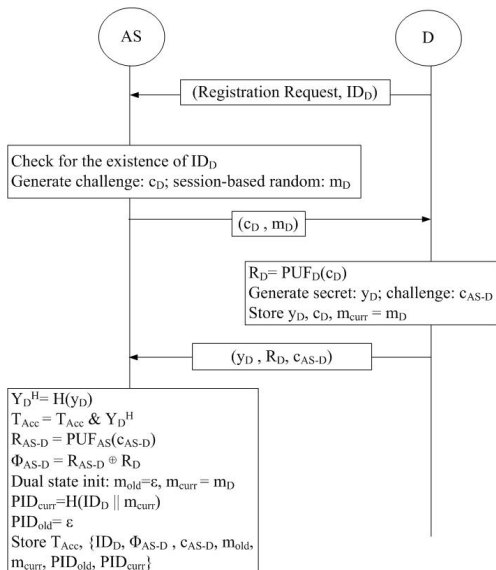
Session 2: $PID_2 = H(ID_D \parallel m_2)$

...

An observer cannot link
 $PID_1, PID_2, \dots$ to the same device.

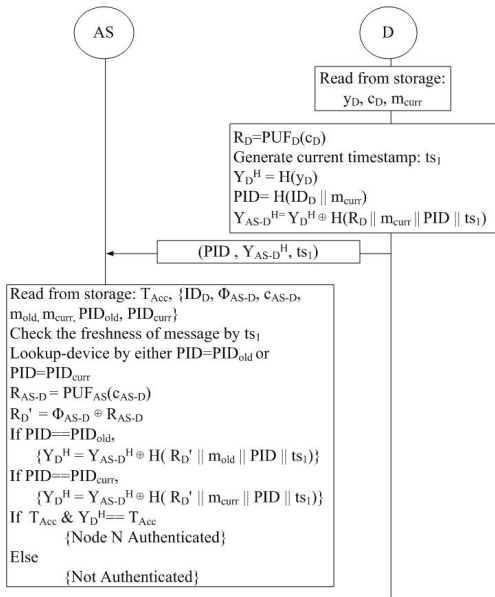
Phase 1 – Node Enrolment (Secure Channel)

- $D \rightarrow AS$: request + ID_D .
- AS issues challenge c_D and session random m_D .
- D computes PUF response $R_D = \text{PUF}_D(c_D)$, picks secret y_D , returns (y_D, R_D, c_{AS-D}) .
- AS folds $H(y_D)$ into accumulator T_{Acc} (bitwise AND), stores $\Phi_{AS-D} = R_{AS-D} \oplus R_D$.
- **Pseudonym init:** AS sets $PID_{curr} = H(ID_D || m_{curr})$, $PID_{old} = \varepsilon$ – the initial **dual state**.



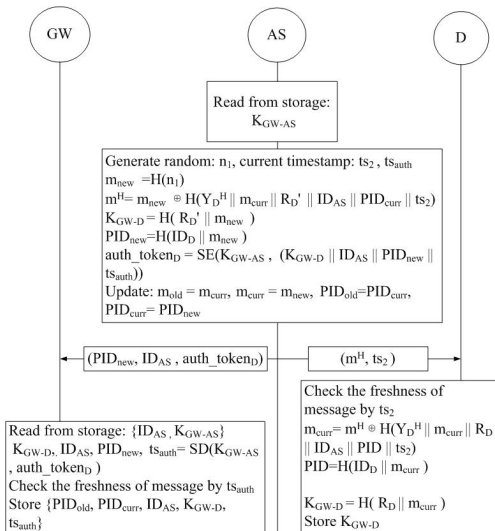
Phase 2 – Node Authentication (Open Channel)

- D regenerates R_D from c_D and computes $PID = H(ID_D || m_{curr})$.
- Sends masked tag $Y_{AS-D}^H = H(y_D) \oplus H(R_D || m_{curr} || PID || ts_1)$.
- Message: (PID, Y_{AS-D}^H, ts_1) – **no** ID_D .
- AS does a **dual-state lookup** (PID_{curr} or PID_{old}), checks ts_1 freshness.
- AS recovers R'_D , unmask $Y_D^{H'}$, verifies via the **accumulator AND-check** ($T_{Acc}^{new} = T_{Acc}$).



Phase 3 – Session Key Exchange (Open Channel)

- AS draws fresh n_1 , sets $m_{\text{new}} = H(n_1)$.
- Session key $K_{GW-D} = H(R'_D \parallel m_{\text{new}})$.
- New pseudonym $PID_{\text{new}} = H(ID_D \parallel m_{\text{new}})$.
- $AS \rightarrow GW$: auth_token_D (encrypted under K_{GW-AS} , carries $K_{GW-D} + PID_{\text{new}}$).
- $AS \rightarrow D$: masked $m_H = m_{\text{new}} \oplus H(\dots) + ts_2$.
- D recovers m_{new} , derives the **same** K_{GW-D} , rotates PID .
- AS & GW advance state: $\text{old} \leftarrow \text{curr}$, $\text{curr} \leftarrow \text{new}$.



Key Idea 2 – Dual-State Desynchronisation Recovery

The problem

- In Phase 3, AS sends (m_H, ts_2) to D .
- If this packet is **lost**, AS has already advanced to m_{new} , but D keeps stale m_{curr} .
- D 's next PID matches nothing $\Rightarrow$ authentication fails.

Base scheme (DAuth): single state $\Rightarrow$ **full re-enrolment**.

Our fix: dual state

AS & GW keep *both* $(m_{\text{curr}}, PID_{\text{curr}})$ and $(m_{\text{old}}, PID_{\text{old}})$.

- Stale D arrives with $PID = PID_{\text{old}}$.
- AS recognises it via dual-state lookup, verifies using m_{old} , and re-synchronises – **no re-enrolment**.
- D 's behaviour is *identical*; only AS adapts.

Trade-off

Tolerates a single consecutive loss; two slots balance storage vs. recovery depth.

Dual-State Recovery – Algorithm

Algorithm 1 Desynchronisation Recovery – Authentication Phase

Precondition: D holds stale $m_{\text{curr}} = m_{\text{old}}$; AS holds $(m_{\text{curr}}, m_{\text{old}}, PID_{\text{curr}}, PID_{\text{old}})$

- 1: $PID = H(ID_D \| m_{\text{curr}})$ $\triangleright$ stale m_{curr} gives $PID = PID_{\text{old}}$
- 2: D sends (PID, Y_{AS-D}^H, ts_1) to AS
- 3: **if** $PID == PID_{\text{curr}}$ **then**
- 4: AS verifies using m_{curr} $\triangleright$ normal path
- 5: **else if** $PID == PID_{\text{old}}$ **then**
- 6: AS verifies using m_{old} $\triangleright$ desync detected
- 7: **else**
- 8: AS rejects D
- 9: **end if**

Algorithm 2 Desynchronisation Recovery – Key Exchange Phase

Precondition: desync path from Algorithm 1; AS uses $m_{\text{old}}, PID_{\text{old}}$

- 1: $n_1 = \text{rand}()$
- 2: $m_{\text{new}} = H(n_1)$
- 3: $m_H = m_{\text{new}} \oplus H(Y_D^{H'} \| m_{\text{old}} \| R'_D \| ID_{AS} \| PID_{\text{old}} \| ts_2)$
- 4: AS sends (m_H, ts_2) to D
- 5: $m_{\text{new}} = m_H \oplus H(Y_D^H \| m_{\text{curr}} \| R_D \| ID_{AS} \| PID \| ts_2)$ $\triangleright D$ uses $m_{\text{curr}} = m_{\text{old}}$ — recovers correctly
- 6: $m_{\text{old}} = m_{\text{curr}}; m_{\text{curr}} = m_{\text{new}}; PID = H(ID_D \| m_{\text{curr}})$

Result: D and AS re-synchronised; PID rotated

Outline

- 1 Introduction
- 2 Background & Literature Survey
- 3 Motivation & Contributions
- 4 Proposed Scheme
- 5 Security & Performance Evaluation**
- 6 Conclusion

Formal Security Analysis – ProVerif

Modelled under the **Dolev–Yao** adversary (full control of the open channel). **All queries satisfied:**

- **Correspondence:** enrolment, both authentication directions, cross-phase binding, key exchange.
- **Secrecy:** session key K_{GW-D} (device & gateway views).
- **Forward secrecy:** m_{new} stays secret.
- **Anonymity:** ID_D unrecoverable from traffic.
- **Offline guessing** resistance.

```
-----  
Verification summary:  
Query inj-event(DeviceEnrolled(id_D_2,id_AS_3)) ==> inj-event(DeviceEnrollmentStarts(id_D_2,id_AS_3)) is true.  
Query inj-event(DeviceAuthenticated(id_D_2,id_AS_3)) ==> inj-event(DeviceAuthenticationStarts(id_D_2,id_AS_3)) is true.  
Query inj-event(AuthenticationServerEnds(id_AS_3,id_D_2)) ==> inj-event(AuthenticationServerStarts(id_AS_3,id_D_2)) is true.  
Query inj-event(AuthenticationEndsFull(id_D_2,id_AS_3,R_D_2,m_D_2)) ==> inj-event(AuthenticationStartsFull(id_D_2,id_AS_3,R_D_2,m_D_2)) is true.  
Query event(DeviceKeyExDone(id_D_2,id_AS_3)) ==> event(DeviceKeyExStarts(id_D_2,id_AS_3)) is true.  
Query not attacker(SecretK_GM_D_Device[]) is true.  
Query not attacker(SecretK_GM_D_GM[]) is true.  
Query not attacker(SecretM_New[]) is true.  
Query not attacker(SecretID_D[]) is true.  
Weak secret SecretK_GM_D_Device is true.
```

ProVerif verification output – all queries return true.

Informal Security Analysis

Replay resistance

Timestamps ($ts_1, ts_2, ts_{\text{auth}}$) + session random m_{curr} in every mask; stale messages fail freshness checks.

MITM resistance

PUF response R_D (unreproducible) and private m_{curr} are embedded in every XOR mask – no forgery possible.

Device anonymity

ID_D sent only once on the secure channel; open channel uses rotating, unlinkable PID .

Forward secrecy

$K_{GW-D} = H(R_D || m_{\text{new}})$; a compromised key reveals nothing about past/future keys.

Theoretical Cost – Enrolment Phase

TABLE: Computational Cost Comparison: Enrolment Phase

Scheme	Operations	Cost (ms)
LAACA	$3T_{\text{hash}}$	0.11
Zhou et al.	$T_{\text{puf}} + 2T_{\text{hash}} + 3T_{\text{rand}}$	0.13
DAuth	$2T_{\text{puf}} + 1T_{\text{hash}} + 4T_{\text{rand}}$	0.15
Proposed	$2T_{\text{puf}} + 2T_{\text{hash}} + 4T_{\text{rand}}$	0.18

Benchmark (avg. 100 iterations): $T_{\text{rand}}=0.0018$ ms, $T_{\text{puf}}=0.0522$ ms, $T_{\text{hash}}=0.0353$ ms, $T_{\text{aes}}=0.0867$ ms.

TABLE: Communication Cost Comparison: Enrolment Phase

Scheme	# Messages	Cost (bits)
LAACA	3	2592
Zhou et al.	5	1344
DAuth	3	1312
Proposed	3	1312

IDs/timestamps = 32 b; hashes/nonces/challenges/ciphertexts = 256 b.

Theoretical Cost – Authentication & Key Exchange Phase

TABLE: Computational Cost Comparison: Authentication & Key Exchange Phase

Scheme	Operations	Cost (ms)
LAACA	$16 T_{\text{hash}}$	0.56
Zhou et al.	$15 T_{\text{hash}}$	0.53
DAuth	$2 T_{\text{puf}} + 8 T_{\text{hash}} + 2 T_{\text{aes}} + 1 T_{\text{rand}}$	0.56
Proposed	$2 T_{\text{puf}} + 11 T_{\text{hash}} + 2 T_{\text{aes}} + T_{\text{rand}}$	0.67

Benchmark (avg. 100 iterations): $T_{\text{rand}}=0.0018$ ms, $T_{\text{puf}}=0.0522$ ms, $T_{\text{hash}}=0.0353$ ms, $T_{\text{aes}}=0.0867$ ms.

TABLE: Communication Cost Comparison: Auth. & Key Exchange Phase

Scheme	# Messages	Cost (bits)
LAACA	3	2400
Zhou et al.	4	2464
DAuth	3	928
Proposed	3	1376

IDs/timestamps = 32 b; hashes/nonces/challenges/ciphertexts = 256 b.

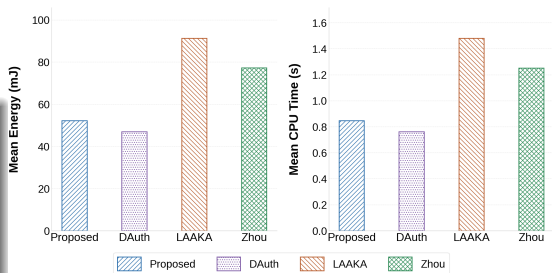
Simulation – Per-Device Cost (COOJA / Contiki-NG)

Setup: 100-node network, RPL Lite, CSMA, CoAP; 20 devices, 2 AS active; 10 random seeds.

Result

Proposed vs. state-of-the-art (per device, all phases):

- Energy: **42.8%** lower than LAAKA, **32.4%** lower than Zhou.
- CPU time: **42.7%** / **32.4%** lower.

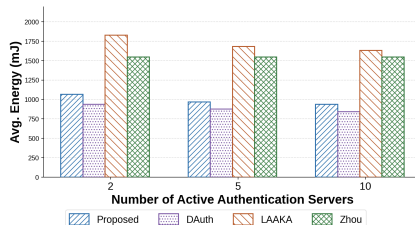


(a) Energy (b) CPU time – mean per device.

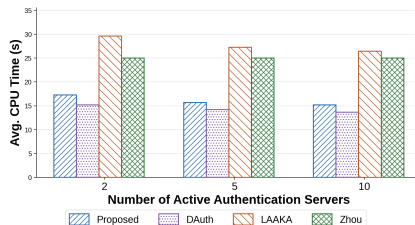
Simulation – Authentication Server Pool Size

AS pool grown from **2 to 10** servers (20 devices).

- Proposed stays $\sim 42\%$ below LAAKA at every pool size.
- Both distributed schemes drop $\sim 11\text{--}12\%$ as the pool grows – extra servers absorb join load.
- Zhou (gateway-coupled) is flat – a centralised design **cannot** exploit AS diversity.



(a) Total energy



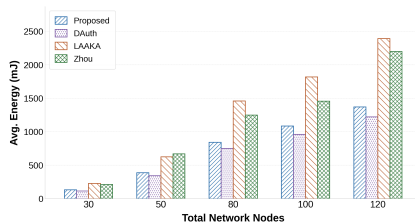
(b) Total CPU time

Simulation – Network Scalability

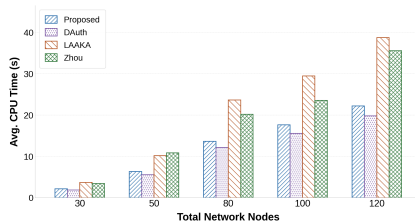
Network size

$N \in \{30, 50, 80, 100, 120\}$ (20% newly-joined devices).

- At $N = 120$: Proposed is **42.7%** below LAAKA and **37.6%** below Zhou in both energy and CPU time.
- LAAKA / Zhou grow steeply (AES-heavy crypto).
- Proposed stays lowest among anonymity-preserving schemes; only a small overhead above DAAuth.



(a) Total energy vs. N



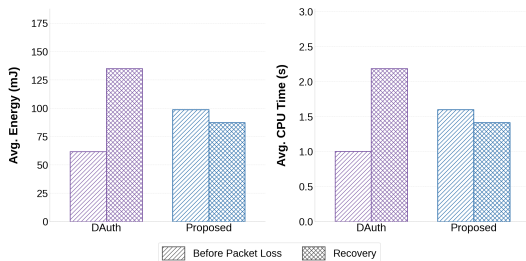
(b) Total CPU time vs. N

Simulation – Desynchronisation Recovery

Per-device cost of one round:

normal vs. **recovery** (round after a packet loss), 100-node network, 20 devices, 5 seeds.

- **DAuth**: recovery round costs **+118.3%** energy (failed auth + full re-enrolment).
- **Proposed**: recovery $\approx$ normal – dual state adds negligible overhead.
- **Net**: **35.3%** lower recovery energy *and* CPU time vs. DAuth.



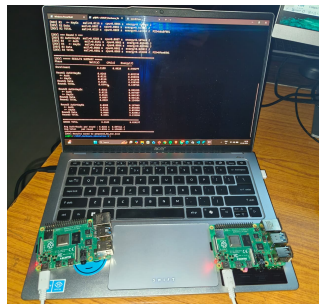
(a) Energy (b) CPU time: normal vs. recovery round.

Hardware Validation – Raspberry Pi 4B Testbed

Setup: 2× RPi 4B (device + AS),
Windows laptop (GW), TCP links;
energy = wall-time × 3.8 W.

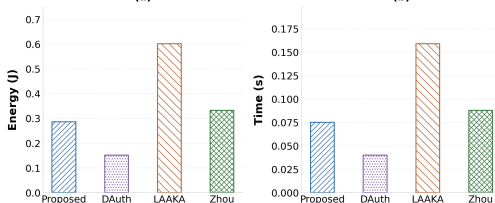
Per-round result

- Energy: Proposed 0.286 J –
14.2% below Zhou, **52.5%**
below LAAKA.
- CPU: Proposed 0.075 s –
14.8% / **52.8%** below Zhou
/ LAAKA.



(a)

(b)



(a) Energy (b) CPU time on RPi 4B.

Outline

- 1 Introduction
- 2 Background & Literature Survey
- 3 Motivation & Contributions
- 4 Proposed Scheme
- 5 Security & Performance Evaluation
- 6 Conclusion**

Conclusion

- Proposed a **lightweight, anonymous, decoupled** distributed authentication scheme for multihop IoT, extending DAuth.
- **Per-session pseudonym rotation** prevents adversarial cross-session tracking – ID_D never appears on the open channel.
- **Dual-state synchronisation** gives transparent desynchronisation recovery *without re-enrolment*.
- PUF-based secrets + hash accumulator + XOR masking keep overhead low.

Validated results

- **ProVerif**: all queries satisfied (correspondence, secrecy, forward secrecy, anonymity).
- **COOJA**: **42.8%** / **32.4%** lower per-device energy than LAAKA / Zhou.
- **Hardware (RPI 4B)**: 0.286 J/round – **52.5%** / **14.2%** below LAAKA / Zhou.

References I



S. Das and M. Khatua, "Lightweight and Decoupled Distributed Authentication for Multihop IoT Networks," in *Proc. IEEE COMSNETS*, 2026.



H. Ali and I. Ahmed, "LAAKA: A Lightweight Anonymous Authentication and Key Agreement Scheme for IoT-Fog Environment," *Computers & Security*, vol. 140, p. 103770, 2024.



X. Zhou, S. Wang, K. Wen, B. Hu, X. Tan, and Q. Xie, "Security-Enhanced Lightweight and Anonymity-Preserving User Authentication Scheme for IoT-Based Healthcare," *IEEE Internet of Things Journal*, vol. 11, no. 6, pp. 9718–9731, 2024.



J. Zhong, S. He, Z. Liu, and L. Xiong, "Lightweight Anonymous Authentication for IoT: A Taxonomy and Survey of Security Frameworks," *Sensors*, vol. 25, no. 17, p. 5594, 2025.



P. Rosa, A. Souto, and J. Cecílio, "Light-SAE: A Lightweight Authentication Protocol for Large-Scale IoT Environments Made with Constrained Devices," *IEEE Trans. Network and Service Management*, vol. 20, no. 3, pp. 2428–2441, 2023.

Thank You!

Anup Kulkarni
Dept. of CSE, IIT Guwahati
Guide: Prof. Manas Khatua